

Security+ 2.3 · Cross-Site Scripting (XSS)

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 2.3 — Cross-Site Scripting (XSS) (8:34) · [Vídeo no YouTube ↗](#)

Resumo da Aula: Injeta JavaScript num site de terceiros que roda COM AS CREDENCIAIS DA VÍTIMA (cookie, sessão). 3 tipos: Refletido (no link — vítima clica), Persistido (fica no DB — afeta todos que ver), DOM-based. Defesa: sanitize/escape output, HttpOnly cookie, CSP (Content Security Policy).

💡 Highlights que a prova cobra

- XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA
- Persistido = armazenado no banco; refletido = vem do query string
- HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing

🎯 Dicas de prova & Cenários Típicos

- 'malicious JavaScript runs in the victim's browser' = XSS
- 'Content Security Policy as defense' = XSS mitigation

Cenário clássico de exame: Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 2.3)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Cross-Site Scripting (XSS)) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Atores de Ameaça (Threat Actors):** **Nation-state / APT (Advanced Persistent Threat):** altamente financiado, sofisticado, motivado por espionagem geopolítica a longo prazo. **Cybercriminal:** motivado por lucro financeiro direto (ransomware, extorsão). **Hacktivist:** motivado por causas políticas ou ideológicas. **Insider Threat:** funcionário ou terceiro com acesso legítimo que abusa de privilégios por dolo ou negligência.
- **Engenharia Social e Variantes de Phishing:** **Phishing:** campanha em massa por e-mail. **Spear Phishing:** ataque direcionado a indivíduo ou empresa específica usando dados de OSINT. **Whaling:** direcionado a executivos do C-level (CEO, CFO). **Vishing:** phishing por voz/telefone. **Smishing:** phishing por SMS. **BEC (Business Email Compromise):** impersonação de diretoria para desvio de faturas ou transferências bancárias.
- **Tipos de Malware e Vetores de Ataque:**
 - *Ransomware:* cifra dados corporativos e exige resgate em criptomoeda.
 - *Trojan:* software aparentemente inofensivo que instala backdoors ocultos.
 - *Rootkit:* modifica o kernel do sistema operacional e se oculta de ferramentas antivírus comuns.
 - *Worm:* malware autorreplicável que se propaga sozinho pela rede sem intervenção humana.
- **Vulnerabilidades de Aplicação (OWASP Top 10):**
 - *SQL Injection (SQLi):* manipulação de queries de banco de dados por falta de sanitização/parametrização (prepared statements).
 - *XSS (Cross-Site Scripting):* injeção de scripts maliciosos (JavaScript) no navegador da vítima.
 - *CSRF (Cross-Site Request Forgery):* induz a vítima logada a executar ações indesejadas em uma aplicação web confiável.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- Phishing não é mitigado apenas por filtros de e-mail; o controle humano fundamental é a simulação periódica de phishing e conscientização.
- Rootkits operam no nível de anel de privilégio (Ring 0 / Kernel), exigindo verificação de Secure Boot (TPM) para prevenção confiável.

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Injetar script malicioso numa página pra rodar no navegador de OUTROS usuários:

- A)** XSS (Cross-Site Scripting)
- B)** CSRF
- C)** SQLi
- D)** Buffer overflow

2. Qual dispositivo de segurança de rede opera na camada de aplicação (Layer 7) e pode inspecionar conteúdo HTTP/HTTPS?

- A)** Firewall stateful tradicional
- B)** Web Application Firewall (WAF)
- C)** Switch Layer 2
- D)** Hub

3. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA...

4. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Persistido = armazenado no banco; refletido = vem do query string'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: '"malicious JavaScript runs in the victim's browser' = XSS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'malicious JavaScript runs in the victim's browser' = XSS...

7. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Content Security Policy as defense' = XSS mitigation'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'Content Security Policy as defense' = XSS mitigation...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'comentário malicioso num fórum executa script em quem vê o coment...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Cross-Site Scripting (XSS)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Persistido = armazenado no banco; refletido = vem do query string'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — XSS (Cross-Site Scripting).

✓ **Por que está certa:** XSS injeta JavaScript que roda no navegador da vítima. Defesa: sanitizar/escapar a saída. SQLi ataca o banco; CSRF força ação autenticada.

✗ **Por que as outras estão erradas:**

- *CSRF:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *SQLi:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Buffer overflow:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) B — Web Application Firewall (WAF).

✓ **Por que está certa:** WAF opera na camada 7 do modelo OSI, inspecionando tráfego HTTP/HTTPS para proteger aplicações web contra ataques como SQL injection e XSS.

✗ **Por que as outras estão erradas:**

- *Firewall stateful tradicional:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Switch Layer 2:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Hub:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) D — Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Persistido = armazenado no banco; refletido = vem do query string.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola

frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): HttpOnly cookie: JavaScript não pode ler — mitiga XSS stealing.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'malicious JavaScript runs in the victim's browser' = XSS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): 'malicious JavaScript runs in the victim's browser' = XSS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: 'Content Security Policy as defense' = XSS mitigation....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): 'Content Security Policy as defense' = XSS mitigation.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Cenário: 'comentário malicioso num fórum executa script em quem vê o coment....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Cenário: 'comentário malicioso num fórum executa script em quem vê o comentário' = XSS persistido..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): XSS roda JavaScript no navegador da VÍTIMA — com os cookies DELA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Persistido = armazenado no banco; refletido = vem do query string....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cross-Site Scripting (XSS)): Persistido = armazenado no banco; refletido = vem do query string.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.